

Critical Bugs Found in PHP Codebase

● CRITICAL BUGS

1. Missing Method: `Helpers::clearOldInputAndErrors()`

File: `app/controllers/AuthController.php:32`

```
php

if (Auth::attempt($data['email'], $data['password'])) {
    error_log("Login successful");
    Helpers::clearOldInputAndErrors(); // ❌ METHOD DOES NOT EXIST
    $this->setFlash('success', l18n::t('auth.login_success'));
}
```

Impact: Fatal Error - Login will crash with "Call to undefined method" **Status:** Method is called but never defined in `app/core/Helpers.php`

2. Infinite Redirect Loop: `back()` Method

File: `app/core/Controller.php:31-35`

```
php

protected function back(): void
{
    $referer = $_SERVER['HTTP_REFERER'] ?? '/';
    $this->redirect($referer);
}
```

Bug: When form validation fails, `validate()` calls `back()`, which redirects to the same form, causing validation to fail again → infinite loop.

File: `app/core/Controller.php:77-81`

```
php
```

```

if (!empty($errors)) {
    $_SESSION['errors'] = $errors;
    $_SESSION['old'] = $data;
    $this->back(); // ❌ INFINITE LOOP RISK
}

```

Impact: Users get stuck in validation loops, server resources exhausted

3. File Extension Bug: JavaScript in CSS Directory

File: `public/assets/css/app.js` (Line 1-95)

```

javascript

// Spare Parts Application JavaScript
document.addEventListener('DOMContentLoaded', function() {
    // ❌ JAVASCRIPT FILE WITH .JS EXTENSION IN CSS DIRECTORY

```

Issue: JavaScript file incorrectly placed in CSS directory with wrong structure **Impact:** Asset loading confusion, maintenance issues

4. Incomplete Validation Rules Parsing

File: `app/core/Controller.php:59-72`

```

php

if (strpos($rule, 'min:') !== false && !empty($value)) {
    $min = (int) substr($rule, strpos($rule, 'min:') + 4);
    // ❌ DOESN'T HANDLE MULTIPLE RULES LIKE "required|min:6|max:50"
    if (strlen($value) < $min) {
        $errors[$field] = sprintf('validation.min', ['min' => $min]);
    }
}

```

Bug: Only checks first occurrence of `min:`, doesn't parse multiple rules properly **Impact:** Validation rules like `required|numeric|min:1|max:100` partially fail

5. Broken Route Normalization

File: `app/core/Router.php:65-71`

```
php

$path = '/' . trim($path, '/');
if ($path !== '/') {
    $path = rtrim($path, '/');
}

// ❌ INCONSISTENT: Root path handling vs other paths
```

Issue: Inconsistent path normalization can cause routing mismatches **Impact:** Some URLs may not match expected routes

6. CSRF Token Never Regenerated

File: `app/core/Helpers.php:19-23`

```
php

public static function generateCsrfToken(): string
{
    if (!isset($_SESSION['_token'])) {
        $_SESSION['_token'] = bin2hex(random_bytes(32));
    }
    return $_SESSION['_token']; // ❌ NEVER REGENERATES
}
```

Bug: CSRF token is generated once and reused throughout session **Impact:** Vulnerable to CSRF attacks via token fixation

7. Validation Method Inconsistency

File: Multiple controllers (ClientController, SupplierController, etc.)

```
php
```

```
$data = $this->validate([
    'type' => 'required',
    'name' => 'required',
    'email' => 'email' // ❌ PHONE/ADDRESS NOT IN VALIDATION
]);
```

// Then manually adding:

```
$data['phone'] = Helpers::input('phone', '');
$data['address'] = Helpers::input('address', '');
```

Bug: Required fields not validated, leading to incomplete data **Impact:** Database integrity issues, missing required fields

● MEDIUM PRIORITY BUGS

8. Error Handling in Database Connection

File: `app/config/DB.php:41-48`

```
php
} catch (PDOException $e) {
    error_log("Query failed: " . $e->getMessage());
    throw $e; // ❌ EXPOSES INTERNAL ERROR DETAILS
}
```

Bug: Raw PDO exceptions exposed to users reveal database structure **Impact:** Information disclosure, security vulnerability

9. JavaScript Button Disable Logic Flaw

File: `public/assets/js/app.js:78-85`

```
javascript
```

```
button.addEventListener('click', function() {
  this.disabled = true;
  const originalText = this.textContent;
  this.textContent = 'Loading...';

  setTimeout(() => {
    this.disabled = false; // ✗ ALWAYS RE-ENABLES
    this.textContent = originalText;
  }, 2000);
});
```

Bug: Button re-enabled after 2 seconds regardless of form submission status **Impact:** Double submissions possible, UI confusion

10. Array Access Without Validation

File: Multiple controller files

```
php

$id = (int) $params['id']; // ✗ NO CHECK IF 'id' KEY EXISTS
$client = $this->clientModel->find($id);
```

Bug: Direct array access without isset() check **Impact:** PHP notices/warnings if URL parameters missing

11. Autoloader Case-Sensitivity Issue

File: app/core/Autoloader.php:53-58

```
php

// Fallback: try lowercase filename (for case-insensitive filesystems)
$fileLower = $baseDir . str_replace('\\', '/', strtolower($relativeClass)) . '.php';
if (self::requireFile($fileLower)) {
  return true;
}
```

Bug: Inconsistent class loading behavior between case-sensitive/insensitive filesystems **Impact:** Code works on Windows but fails on Linux servers

IMMEDIATE FIXES REQUIRED

Fix 1: Add Missing Method

```
php

// Add to app/core/Helpers.php
public static function clearOldInputAndErrors(): void
{
    unset($_SESSION['errors'], $_SESSION['old']);
}
```

Fix 2: Prevent Infinite Redirects

```
php

// Update app/core/Controller.php validate() method
if (!empty($errors)) {
    $_SESSION['errors'] = $errors;
    $_SESSION['old'] = $data;

    // Prevent infinite loops by checking referer
    $referer = $_SERVER['HTTP_REFERER'] ?? '/';
    if (strpos($referer, $_SERVER['REQUEST_URI']) !== false) {
        $referer = '/dashboard'; // Safe fallback
    }
    $this->redirect($referer);
}
```

Fix 3: Move JavaScript File

```
bash

# Move misplaced file
mv public/assets/css/app.js public/assets/js/app-extra.js
```

Fix 4: Fix Validation Rules Parser

```
php
```

// Replace validation logic in Controller.php

```
private function parseValidationRule(string $rule, string $field, $value): ?string
{
    $rules = explode('|', $rule);

    foreach ($rules as $singleRule) {
        if ($singleRule === 'required' && empty($value)) {
            return I18n::t('validation.required', ['field' => $field]);
        }

        if ($singleRule === 'email' && !empty($value) && !filter_var($value, FILTER_VALIDATE_EMAIL)) {
            return I18n::t('validation.email');
        }

        if (strpos($singleRule, 'min:') === 0) {
            $min = (int) substr($singleRule, 4);
            if (!empty($value) && strlen($value) < $min) {
                return I18n::t('validation.min', ['min' => $min]);
            }
        }

        if ($singleRule === 'numeric' && !empty($value) && !is_numeric($value)) {
            return "The {$field} must be a number";
        }
    }

    return null;
}
```

Fix 5: Secure CSRF Tokens

php

```
// Update Helpers.php
public static function generateCsrfToken(): string
{
    // Regenerate token periodically
    if (!isset($_SESSION['_token']) ||
        !isset($_SESSION['_token_time']) ||
        (time() - $_SESSION['_token_time']) > 3600) {

        $_SESSION['_token'] = bin2hex(random_bytes(32));
        $_SESSION['_token_time'] = time();
    }

    return $_SESSION['_token'];
}
```

Bug Impact Summary

Priority	Bug Count	Severity	Production Impact
 Critical	4	Fatal Errors, Infinite Loops	Application Breaks
 High	3	Security, Logic Issues	Security Vulnerabilities
 Medium	4	UX, Reliability Issues	Poor User Experience
TOTAL	11	Mixed	High Risk

Action Required

1. **IMMEDIATE:** Fix the missing `clearOldInputAndErrors()` method (breaks login)
2. **URGENT:** Resolve infinite redirect loop in validation
3. **HIGH:** Move misplaced JavaScript file
4. **MEDIUM:** Implement proper validation rule parsing
5. **IMPORTANT:** Add input sanitization and error handling

The application has several critical bugs that would cause fatal errors in production. These must be fixed before deployment.